

Návrh síťové segmentace — Ostravia Trade ISP

Autor: Rubicon s.r.o. | Datum: Červen 2026 | RouterOS 7.23.1

1. Stávající stav — analýza problémů

1.1 Topologie

```
Internet (GTS)
  | 194.108.250.73/30
  |
CCR2116-12G-4S+ (RouterOS 7.23.1)
"Ostravia Trade ISP"
  | ether2 (10.131.161.x/24 – všechny podsítě)
  |
Eagle switch (.254, RouterOS, Winbox:8292)
  |
MASTER CSS326-24G-2S+ (.251, SwOS, web:8081) "Ostravia 40-1"
├─ P1–P23: místnosti 10,42,43,45,49,51,52,89,91,93,94,97,
│          130,131,132,133/1,133/2,201,Bistro,Výměník,
│          Malá zasedačka,Velký sál, LinkSwitch2
└─ P24: UPLINK → Eagle
    |
    └─ P23 (LinkSwitch2) ↔ P24 (LinkSwitch1)
        |
        SLAVE CSS326-24G-2S+ (.250, SwOS, web:8082) "Ostravia 40-2"
        └─ P1–P23: místnosti 229,233,235,301,373,402,403,404,
            416,430/1,430/2,504, Port13–Port23
            └─ P24: LinkSwitch1 → MASTER
```

VIP klienti (samostatné fyzické porty, beze změn):

- ether10 → Llentab (194.108.11.48/29)
- ether11 → Ostravia (194.108.11.32/30)
- ether12 → Siemens (disabled)

1.2 Identifikované problémy

#	Problém	Závažnost	Dopad
P1	Port isolation na CSS326 NENÍ zapnutá	KRITICKÁ	Každý tenant vidí L2 broadcast všech ostatních, může ARP-sniffovat, ARP-spoofovat
P2	VLANY na CSS326 NEJSOU nakonfigurovány	KRITICKÁ	Jeden flat L2 segment pro ~32 firem
P3	CCR2116 forward chain acceptuje veškerý cross-tenant provoz	KRITICKÁ	Tenant A může routovat provoz do sítě tenanta B přes gateway CCR2116
P4	DHCP Snooping — všechny porty trusted	VYSOKÁ	Jakýkoli tenant může spustit rogue DHCP server a přidělovat IP adresy ostatním
P5	SNMP community = "public"	STŘEDNÍ	Kdokoli na LAN čte statistiky a konfiguraci switchů
P6	IPSec enc-algorithm = 3DES	STŘEDNÍ	Zastaralý algoritmus (RFC 8996, Sweet32 attack)
P7	PPTP VPN zapnutý	STŘEDNÍ	Prolomitelné šifrování, Microsoft nedoporučuje od 2012
P8	SSH forwarding-enabled=remote	STŘEDNÍ	Umožňuje tunelování libovolného provozu mimo firewall
P9	Credentials v backup scriptu plaintext	STŘEDNÍ	FTP heslo viditelné v .rsc exportu
P10	DNS open resolver na LAN	NÍZKÁ	DNS zneužitelný z tenant sítí
P11	Blackhole pool bez explicitního drop	NÍZKÁ	Neznámá zařízení nemají gateway, ale drop není vynucen FW

1.3 Proč stávající DHCP-based izolace nestačí

Přidělení IP dle MAC adresy v DHCP: - **Chrání pouze před náhodným přiřazením** — tenant, který nastaví IP staticky, dostane přístup do libovolné /29 podsítě - **Neřeší L2 komunikaci** — tenant s IP 10.131.161.4 může přímo ARP-ovat na 10.131.161.66 (jiný tenant) a komunikovat bez průchodu routerem - **Neřeší multicast/broadcast** — broadcast od jednoho tenanta vidí všichni ostatní

2. Navrhovaná architektura

2.1 Cíle

- **L2 izolace:** Tenanti nesmí vidět vzájemné L2 broadcast, ARP, ani přímo komunikovat
- **L3 izolace:** Provoz mezi tenant subnety musí být blokován na CCR2116
- **Nulový dopad na klienty:** Žádná rekonfigurace na straně tenanta, žádný výpadek přístupu k internetu
- **Zachování VIP klientů:** ether10 (Llentab), ether11 (Ostravia), ether12 (Siemens) beze změny
- **Jedna firma = více místností:** Lze přiřadit stejný VLAN ID více portům

2.2 Nová topologie (po implementaci)

```
Internet (GTS)
|
| 194.108.250.73/30
|
CCR2116-12G-4S+
ether1 = WAN
ether2 = VLAN trunk (tagged)
bridge-isp (vlan-filtering=yes)
├─ vlan101 → 10.131.161.1/29 (#01, DHCP server)
├─ vlan102 → 10.131.161.9/29 (#02, DHCP server)
├─ ...
├─ vlan132 → 10.131.161.249/29 (#32, DHCP server)
└─ vlan199 → 10.131.162.1/29 (Dalkia, DHCP server)
    |
    | tagged trunk
    |
Eagle switch (RouterOS)
- trunk, přenáší všechny VLANy tagged
  |
  | tagged trunk
  |
MASTER CSS326 (SwOS)
├─ P1 (PVID=101, access) → místnost 10 → tenant #01
├─ P2 (PVID=102, access) → místnost 42 → tenant #02
└─ ...
```

```

├─ P23 (trunk, tagged) → SLAVE CSS326
├─ P24 (trunk, tagged) → Eagle
│
SLAVE CSS326 (SwOS)
├─ P1 (PVID=xxx, access) → místnost 229 → tenant #xx
├─ ...
└─ P24 (trunk, tagged) → MASTER

```

2.3 Princip VLAN transparentnosti pro klienta

Klientovo zařízení:

posílá: [untagged frame | src: MAC-klienta | dst: gateway]

↓

CSS326 access port (PVID=101):

přidá tag: [VLAN101 tag | src: MAC-klienta | dst: gateway]

↓

Eagle → CCR2116 bridge-isp → interface vlan101

↓

CCR2116 zpracuje, src-NAT → internet

↓

odpověď přijde na vlan101 → Eagle → CSS326

CSS326 odstraní VLAN101 tag → klient dostane [untagged frame]

Klient nevidí žádné VLAN tagy, konfigurace se ho netýká.

3. Fáze 1 — Okamžité opravy (bez výpadku, ~20 min)

3.1 CSS326 MASTER (SwOS, IP: 10.131.161.251, přístup: :8081)

A) Port Isolation zapnout

- Záložka **Ports** → sloupec **Isolation**
- Zaškrtnout: **P1 - P23**
- Nezaškrtnout: **P24** (uplink — musí být průchozí pro veškerý provoz)
- Kliknout **Apply**

Proč: Port isolation zajistí, že každý přístupový port komunikuje výhradně přes uplink (P24). Dva tenanti na P1 a P2 si nemohou posílat pakety přímo na L2 — veškerý jejich provoz jde přes Eagle → CCR2116, kde ho firewall může zachytit.

B) DHCP Snooping — opravit trusted porty

- Záložka **System** → sekce **DHCP & PPPoE Snooping**
- **Důvěryhodné přístavy:** odškrtnout P1-P23, ponechat pouze **P24**
- Kliknout **Apply**

Proč: Pokud jsou všechny porty trusted, DHCP snooping nechrání před tím, aby si tenant spustil vlastní DHCP server. Pouze uplink (P24) přináší legitimní DHCP odpovědi od CCR2116.

C) SNMP community

- Záložka **SNMP** → pole **Community** → změnit z public na silný řetězec
- Kliknout **Apply**

3.2 CSS326 SLAVE (SwOS, IP: 10.131.161.250, přístup: :8082)

Stejně kroky jako MASTER (viz 3.1 A, B, C). - Port isolation: P1-P23 zaškrtnout, P24 (LinkSwitch1 → MASTER) nezaškrtnout - DHCP Snooping: pouze P24 trusted

3.3 CCR2116 — firewall a bezpečnostní opravy

Soubor: phase1-immediate-fixes.rsc — importovat přes Winbox nebo SSH:

```
/import file-name=phase1-immediate-fixes.rsc
```

Obsahuje: - DROP pravidla pro cross-tenant provoz (10.131.161.x ↔ 10.131.161.x) - DROP pro blackhole pool (10.131.190.0/24) - Oprava IPSec: 3DES → AES-256-GCM - Zakázání PPTP - Oprava SSH forwarding - Omezení DNS resolveru

4. Fáze 2 — VLAN segmentace (maintenance window ~30 min)

4.1 Prerekvizity před maintenance window

1. Ověřit přístup na Eagle switch (Winbox port 8292)
2. Mít konzolový přístup na CCR2116 (pro případ výpadku management přístupu)
3. Záloha CCR2116 před změnami: `/system backup save name=pre-vlan-backup`

4.2 Postup (pořadí je důležité)

Krok 1: CCR2116 – vytvořit bridge-isp + VLAN interfacy (bez přesunu ether2)
→ Vytvoří novou síťovou strukturu, ether2 zatím stále funguje nezávisle
→ Doba: ~5 min, žádný výpadek

Krok 2: Eagle switch – nakonfigurovat VLAN trunk (dle konkrétní platformy)
→ Přidat tagged porty pro všechny VLANy na uplink k CCR2116 a downlink k MASTER

Krok 3: CSS326 MASTER + SLAVE – nastavit PVID per port + trunk porty
→ Každý přístupový port dostane PVID odpovídající tenantovi
→ P24/P23 jako tagged trunk

Krok 4: CCR2116 – přidat ether2 do bridge-isp + přesunout IP adresy + DHCP
 → TOTO JE MAINTENANCE WINDOW (~5 min výpadek)
 → Provést přes konzoli (ne Winbox přes ether2!)

Krok 5: Ověření konektivity

4.3 VLAN mapování portů — MASTER CSS326

Port	Název	PVID (VLAN)	Podsít tenanta
P1	P1-10	101	10.131.161.0/29
P2	P2-42	102	10.131.161.8/29
P3	P3-43	103	10.131.161.16/29
P4	P4-45	104	10.131.161.24/29
P5	P5-49	105	10.131.161.32/29
P6	P6-51	106	10.131.161.40/29
P7	P7-52	107	10.131.161.48/29
P8	P8-89	108	10.131.161.56/29
P9	P9-91	109	10.131.161.64/29
P10	P10-93	110	10.131.161.72/29
P11	P11-94	111	10.131.161.80/29
P12	P12-97	112	10.131.161.88/29
P13	P13-130	113	10.131.161.96/29
P14	P14-131	114	10.131.161.104/29
P15	P15-132	115	10.131.161.112/29
P16	P16-133/1	116	10.131.161.120/29
P17	P17-133/2	116	10.131.161.120/29 (stejná firma jako P16)
P18	P18-201	118	10.131.161.136/29
P19	P19-Bistro	119	10.131.161.144/29
P20	P20-Výměník	120	10.131.161.152/29
P21	P21-Malá zasedačka	121	10.131.161.160/29
P22	P22-Velký sál	122	10.131.161.168/29
P23	LinkSwitch2	trunk	tagged: 101-132, 199
P24	UPLINKEagle	trunk	tagged: 101-132, 199

Poznámka: PVID 117 je rezervováno pro Dalkia (10.131.162.0/29 = vlan199).
 Mapování PVID → podsít je flexibilní; pořadí v tabulce odpovídá pořadí DHCP
 leasů v konfiguraci.

4.4 VLAN mapování portů — SLAVE CSS326

Port	Název	PVID (VLAN)	Podsít tenanta
P1	P1-229	123	10.131.161.176/29

Port	Název	PVID (VLAN)	Podsít' tenanta
P2	P2-233	124	10.131.161.184/29
P3	P3-235	125	10.131.161.192/29
P4	P4-301	126	10.131.161.200/29
P5	P5-373	127	10.131.161.208/29
P6	P6-402	128	10.131.161.216/29
P7	P7-403	129	10.131.161.224/29
P8	P8-404	130	10.131.161.232/29
P9	P9-416	131	10.131.161.240/29
P10	P10-430/1	132	10.131.161.248/29
P11	P11-430/1	132	10.131.161.248/29 (stejná firma jako P10)
P12	P12-504	199	10.131.162.0/29 (Dalkia)
P13-P23	nepojmenované	dle potřeby	k přiřazení
P24	LinkSwitch1	trunk	tagged: 101-132, 199

5. Ověření po implementaci

Fáze 1 — checklist

- ☐ Z IP tenanta #01 (10.131.161.2-6): ping 10.131.161.10 → **Request timeout** (drop)
- ☐ Z IP tenanta #01: ping 8.8.8.8 → **OK** (internet funguje)
- ☐ Spustit DHCP server na libovolném přístupovém portu CSS326 → CCR2116 alert email dorazí
- ☐ SNMP community "public" → snmpwalk -c public 10.131.161.251 → **Timeout** (nefunguje)
- ☐ VIP klienti: ping 194.108.11.34 (Ostravia router) → **OK** (nedotčeno)

Fáze 2 — checklist

- ☐ DHCP lease: klient dostane IP ze správné /29 podsítě (stejná jako dříve)
- ☐ Gateway ping: klient pinge svou gateway (pr. 10.131.161.1) → **OK**
- ☐ Cross-tenant ping → **Request timeout**
- ☐ CCR2116: /ip dhcp-server lease print → leasy viditelné per VLAN server
- ☐ CCR2116: /interface bridge host print → MAC adresy ve správných VLANech
- ☐ NAT: curl ifconfig.me z klienta → dostane svou přiřazenou veřejnou IP

6. Bezpečnostní opravy — souhrn

Oprava	Důvod
3DES → AES-256-GCM (IPSec)	RFC 8996 zakazuje 3DES; Sweet32 útok (2016)
Zakázat PPTP	Prolomitelné MS-CHAPv2 šifrování; nahradit WireGuard nebo L2TP/IPSec
SSH forwarding=no	Remote port forwarding umožňuje obcházet firewall
DNS restrict	Omezit allow-remote-requests jen na management/loopback
Credentials v scriptech	Přesunout FTP heslo z backup-ftp scriptu do /system environment
Telegram bot token	Přesunout z netwatch scriptů do proměnné nebo Vault

7. Budoucí doporučení

1. **Nemanageable switche v patrech** — postupně nahradit za CSS326 nebo CRS326. Dokud existují, L2 izolace platí jen do úrovně CSS326 MASTER/SLAVE. Zařízení za nemanageable switchem sdílejí L2 navzájem (ale ne s ostatními nájemníky).
2. **802.1X autentizace** — pro enterprise prostředí; každý port vyžaduje autentizaci certifikátem nebo heslem před přidělením VLAN. Vyžaduje RADIUS server.
3. **IPv6** — aktuálně žádná IPv6 konfigurace. Zvážit při rozšíření.
4. **WireGuard VPN** — nahradit PPTP pro vzdálený přístup zaměstnanců.
5. **Per-tenant monitoring v Dude** — po VLAN migraci snadno přidat per-tenant grafy sledující provoz na vlan101-vlan132 interface.